

大型三甲医院数据治理平台

建设失败案例、反模式、预警信号与复盘手册

文档版本	V1.0
设计基线日期	2026-07-15
适用对象	大型综合三级甲等医院、多院区医疗集团
文档用途	立项、招标、详细设计、PoC、实施、验收与运行交接
保密级别	医院内部/项目受控

本说明书给出可落地的参考架构与验收基线。具体品牌、版本、数量和参数须以医院真实数据剖析、兼容性 PoC、性能压测和安全评审为准。

使用说明

本手册用于方案评审、招标条款、PoC、上线 Go/No-Go、重大故障和阶段复盘。公开案例用于提取普适教训；“综合案例”是对医院项目常见反模式的归纳，不指向某一具体医院或厂商。

复盘原则	要求
患者安全优先	所有患者身份、药品、医嘱和临床接口问题先评估患者影响，不能只按 IT 故障处理
事实与证据	保留时间线、日志、版本、数据快照、告警、操作和决策记录
系统性根因	区分直接原因、促成因素、组织/流程/技术控制缺失
不归咎个人	聚焦为什么系统允许错误发生和扩散
整改闭环	每项措施有责任人、期限、验证方法和防复发指标

1. 失败模式总览

编号	失败模式	典型后果	核心控制
F01	范围失控/大一统	成本与周期失控，业务不采用	阶段收益、退出门槛、共存架构
F02	大爆炸上线	临床效率和安全风险集中释放	影子/双查/灰度/降级
F03	MDM 字典化	各系统仍私有维护	权威发布权、接入合同、退役旧入口
F04	EMPI 误合并	患者串档	双阈值、人工灰区、回滚
F05	CDC 影响源库	生产库性能/日志事故	逐库 PoC、限速、回灌隔离
F06	Kafka 无治理	积压、重复、Schema 破坏	契约、幂等、DLQ、SLO
F07	元数据墓地	目录无 Owner、无使用	核心域先行、Owner/申请/KPI
F08	状态组件共故障域	单点故障全平台停摆	独立资源池、拓扑、容量红线
F09	隐私后补	项目暂停、信任受损	PIPIA、用途、最小必要、科研沙箱
F10	灾备纸面化	备份不可恢复、RTO 失控	恢复演练、WORM、全链路切换
F11	供应商锁定	升级和退出受制	开放格式、源码/配置托管、退出条款
F12	运营无人负责	规则和目录半年失效	Steward、SLO、月度运营、考核

2. 公开案例一：英国 NHS NPfIT

NAO 2011 年报告显示，该国家级 IT 计划的电子病历部署速度远低于预期，核心目标无法实现；交付系统数量减少但成本没有相应下降，急性医院所获功能更多是行政管理而非预期临床功能。报告认为项目根本低估了大型 IT 变革的规模和复杂性。[S26]

观察	对医院数据治理平台的含义
强中心化替换	不应一次替换全部业务系统，应采用注册、整合、共存和渐进迁移
范围和合同过大	按数据域、系统和成果拆包；阶段性 Go/No-Go
临床收益不足	每期必须绑定临床/运营收益，而不是只交付平台菜单
成本未随范围下降	合同需允许缩减范围、调整费用和退出
本地适配不足	域 Owner、Steward 和一线用户必须参与模型、规则和 UAT

Go/No-Go 问题：试点是否已有真实下游使用？临床/业务是否愿意停止私有字典？是否可以用现有系统共存而非替换？没有肯定答案时不得扩大范围。

3. 公开案例二：Royal Free / DeepMind

ICO 调查认为试验阶段在公平透明、合法基础、患者告知和数据处理范围方面存在问题。教训不是“不能创新”，而是创新必须建立在明确用途、合法基础、最小必要、透明和可审计之上。[S27]

失败点	预警信号	控制
未前置影响评估	先给数据后补审批	PIPIA/伦理/合同在出域前完成
用途边界模糊	“为了 AI/科研”笼统描述	用途代码、数据字段、时间窗、人员、环境逐项批准
数据范围过大	全量患者、全字段、长期访问	最小数据集、去标识化、短期授权
患者/公众透明不足	无法解释数据为何、如何被使用	公开说明、内部登记、可追溯投诉处理
退出和销毁不清	项目结束仍可访问	项目到期自动回收、封存/销毁证明

4. 综合案例：EMPI 误合并导致患者串档

场景：医院为了提高自动化率，将姓名、生日、手机号相似的记录自动合并，但忽略证件冲突、双胞胎、历史手机号复用和监护人代办，导致不同患者的检验、过敏和处方被串联。

阶段	缺失控制	应有控制
需求	把“自动合并率”作为主要 KPI	以误合并为 0、人工灰区及时率为核心
数据	未用真实样本评估缺失和冲突	患者 5-10 万样本剖析，按人群分层
算法	单一加权分数、无禁止规则	确定性+概率+硬冲突规则+双阈值
流程	算法直接写金记录	高风险四眼复核、可解释证据
发布	无下游影响和补偿	合并事件、消费确认、补偿和回滚
运营	无人持续抽检模型	周抽样、漂移监控、阈值变更审批

立即处置：停止自动合并；锁定受影响主记录；导出下游影响清单；临床安全复核；按快照回滚；发布补偿事件；通知相关科室；重新验证阈值。

5. 综合案例：MDM 退化为 Excel 字典搬运

场景：项目把附件中的字典导入新系统，做了查询页面，但 HIS、EMR、LIS 和报表仍各自维护；变更仍通过微信群、邮件和 SQL。半年后编码再次不一致。

- 根因：没有赋予平台发布权，没有域 Owner 和 Steward，没有订阅 SLA，没有新系统接入门槛。
- 预警：平台日活极低；新增系统未调用接口；旧维护页面仍开放；发布记录为空。
- 规避：把现有 121 项对象转成版本化 CodeSystem/ValueSet/ConceptMap；选择 10-20 个高影响词表先强制统一发布；采购合同要求新系统消费标准服务；稳定后关闭旧维护入口。

6. 综合案例：CDC 压垮生产数据库

场景：为追求“全实时”，未经厂商和 DBA 评估就在核心 Oracle/SQL Server 开启全库 CDC 和初始快照，导致日志归档、IO、LOB 读取和 DDL 异常，临床业务性能下降。

预防门槛	要求
逐库 PoC	选关键表，测 CPU、IO、日志、锁、延迟、网络和位点恢复
初始快照	离峰、限速、分表分片；大表优先备库或导出文件
范围	只采关键表和字段，禁止默认全库
安全开关	平台和源库均能一键停采；不影响原交易
回灌隔离	历史回灌与在线 CDC 分资源池、分 Topic 和限额
DDL/LOB	明确支持矩阵、失败策略和人工变更窗口

7. 综合案例：Kafka 消息堆积与重复副作用

场景：Topic 命名和 Schema 无人治理，消费者失败后持续重试，Lag 增长；恢复时同一事件重复执行，造成状态反复或重复写入。院内已有接口消息堆积和补推运维经验，说明事件平台必须把可靠性、幂等和责任人制度化。

- 每个 Topic 登记 Owner、消费者、Key、分区、保留、敏感级、Schema 和 SLA。
- 消费者以 eventId 建立 Inbox 幂等；业务写入和消费确认同一事务。
- 重试次数受控，超过阈值进入 DLQ 并自动生成工单；DLQ 不能只长期堆积。
- 患者合并、药品停用、人员离职等事件要求消费确认和高优先级告警。
- 上线前执行断开 30 分钟、恢复、重复、乱序、Schema 演进和回放测试。

8. 综合案例：元数据目录成为资产墓地

场景：一次性连接上百套数据库，目录里出现数十万张表，但没有业务名称、Owner、质量、申请入口和使用反馈，用户仍通过熟人找数据。

错误 KPI	替代 KPI
接入系统数/表数	核心域 Owner 覆盖率、正式资产活跃率
采集成功率	搜索到申请转化率、申请交付周期
血缘边数量	核心指标/数据产品可追溯率
词条总数	有效定义、使用次数、争议关闭率
页面访问量	数据复用、重复开发下降、质量问题闭环

9. 综合案例：所有有状态组件共用小型 Kubernetes

场景：为了节省服务器，把 Kafka、PostgreSQL、OpenSearch、对象存储、目录、监控都放在同一小集群。一次节点维护、磁盘满或 CNI 故障导致整个数据平台同时不可用。

- 数据库、Kafka、OpenSearch 数据节点和 Ceph 优先独立资源池；低 IO 无状态服务才共享通用 Worker。
- 跨宿主机/机架反亲和，PDB 和拓扑分布；不能把“Pod 有 3 副本”误认为跨故障域 HA。
- 磁盘达到 70-75%开始扩容，80%触发高等级告警；对象存储和日志保留必须有成本模型。
- 维护窗口前验证容量、PDB、备份和回退；禁止同时升级多个基础组件。

10. 综合案例：备份成功但无法恢复

场景：每日备份任务显示成功，但第一次真实恢复时发现 WAL 缺失、证书和密钥未备份、对象存储版本不一致、DNS 和第三方白名单未配置，恢复远超 RTO。

控制	验收证据
数据库 PITR	隔离环境恢复到指定时间，核心对象和审计一致
对象存储	随机对象、checksum、Iceberg 快照和 Catalog 一致
密钥证书	双人授权恢复，服务能解密且产生新审计
K8s 重建	从 Git/Harbor/备份在新集群恢复关键服务
跨中心切换	DNS、路由、统一认证、外部接口和消费者全链路通过
误操作恢复	患者误合并、标准误发布和审计误删均可回退

11. 上线前红线与 Go/No-Go 清单

红线	No-Go 条件
患者安全	存在未解释的误合并、串档、药品停用未传播或关键接口数据错配
数据质量	阻断级规则不能阻断，或质量工单无 Owner
回退	合并、标准、数据库、接口和部署回退未演练
接口可靠性	消费者无幂等/DLQ/补偿；断连恢复测试失败
性能	基准峰值和 1.5 倍压测未通过，或源系统影响超阈值
安全	PIPIA、分类分级、越权测试、审计或密钥恢复未完成
灾备	备份恢复或跨中心演练未通过
组织	域 Owner/Steward 未任命，业务部门拒绝承担审批和质量责任

12. 重大事件复盘模板

栏目	填写要求
事件摘要	发生时间、发现方式、影响对象/系统/患者、持续时间、当前状态
时间线	以分钟级记录告警、操作、决策、沟通和恢复节点
患者/业务影响	患者安全、临床流程、收费、报告、运营、监管和数据泄露影响
技术根因	代码、配置、数据、容量、依赖、发布、故障域或安全控制
促成因素	监控、流程、培训、组织、合同、测试和文档缺陷

栏目	填写要求
处置评价	哪些有效、哪些延误、是否触发应急和回退
整改措施	短期止血、中期修复、长期制度化；责任人、期限、验证
防复发指标	新增告警、测试、门禁、SLO、质量规则或合同条款
经验传播	操作手册、培训、设计规范和其他系统横向排查

附录 参考资料

[S04] 国家互联网信息办公室：《中华人民共和国个人信息保护法》

https://www.cac.gov.cn/2021-08/20/c_1631050028355286.htm（访问日期：2026-07-15）

[S05] 国家互联网信息办公室：《中华人民共和国数据安全法》

https://www.cac.gov.cn/2021-06/11/c_1624994566919140.htm（访问日期：2026-07-15）

[S26] UK National Audit Office：The National Programme for IT in the NHS

<https://www.nao.org.uk/reports/the-national-programme-for-it-in-the-nhs-an-update-on-the-delivery-of-detailed-care-records-systems/>（访问日期：2026-07-15）

[S27] UK Information Commissioner’ s Office：Royal Free / DeepMind investigation

<https://ico.org.uk/about-the-ico/media-centre/news-and-blogs/2017/07/royal-free-google-deepmind-trial-failed-to-comply-with-data-protection-law/>（访问日期：2026-07-15）